

Information Security

(CS3002)

Student Name _____ Roll No _____ Section _____ Student Signature _____

Date: December 17, 2024

Course Instructor(s)

Dr. Sufian, Dr. Aqsa, Dr. Nausheen, Dr. Farrukh,
Mr. Usman, Ms. Hira, Ms. Yusra

Final Exam (solution)

Total Time: 3 Hours

Total Marks: 100

Total Questions: 8

Semester: FA-2024

Campus: Karachi

Dept: CS/SE/AI

Instructions:

- All questions must be answered in answer script and according to the sequence given in the question paper.
- Illustrate/Design/Architect means you have to answer with the help of Diagram/Figure. Written answers will not be graded where illustrations are required. Most of the questions here require Illustrations (figures/algorithm) and unnecessary text will not be graded.
- Return the question paper.

CLO # 1: Explain key concepts of information security such as design principles.

Q1a: Alice uses a XOR cipher to send messages to Bob. She sends two messages $C1 = M1 \oplus K$ and $C2 = M2 \oplus K$. Eve captures both messages, but mixes up their order. Fortunately, Eve

knows that the plaintext M2 is in one of the messages. How can Eve recover the correct M1 and K?
[05 marks]

$$\begin{aligned}C1 &= M1 \oplus K \\C2 &= M2 \oplus K \\C1 \oplus C2 &= M1 \oplus M2\end{aligned}$$

$$C1 \oplus C2 \oplus M2 = M1 \oplus M2 \oplus M2 = M1$$

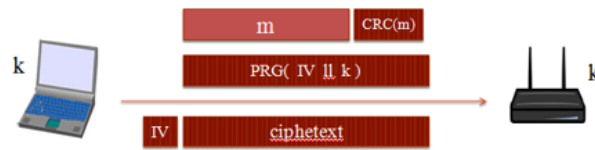
OR

$$\begin{aligned}C2 &= M2 \oplus K \\C2 \oplus M2 &= M2 \oplus K \oplus M2 = K\end{aligned}$$

$$C1 \oplus K = M1 \oplus K \oplus K = M1$$

Q1b: WEP uses stream cipher for confidentiality. Explain the inherent weakness of WEP. How these weaknesses can be exploited to extract the secret key?
[05 marks]

802.11b WEP:



Length of IV: 24 bits

- Repeated IV after $2^{24} \approx 16M$ frames
- On some 802.11 cards: IV resets to 0 after power cycle

key for frame #1: $(1 || k)$

key for frame #2: $(2 || k)$

⋮

24 bits 104 bits

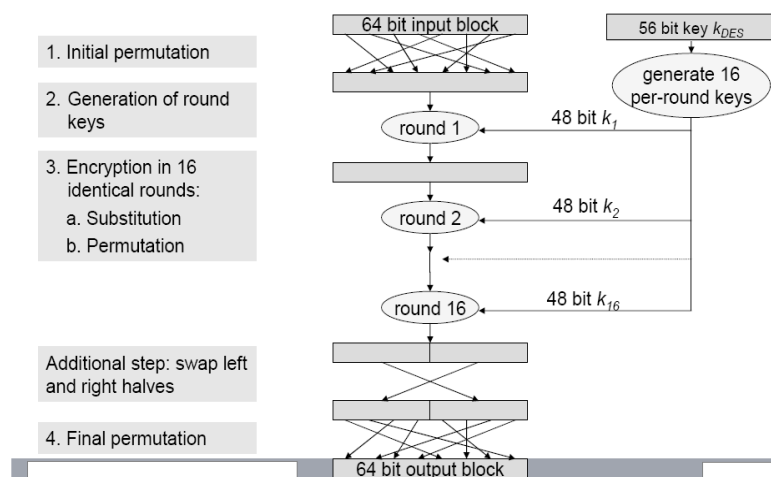
For the RC4 PRG:

FMS2001 $\Rightarrow$ can recover k after 10^6 frames
Recent attacks $\approx 40,000$ frames

CLO # 1: Explain key concepts of information security such as design principles.

Q2a: Outline and illustrate the key steps of DES Encryption process.

[05 marks]



Q2b: PBC (Plain Block Chaining) is a new block cipher mode that adds the plaintext message P_i to the encrypted message C_i as depicted in the figure 1: [05 marks]

- Write down the encryption and decryption function for PBC (Plain Block Chaining).
- How many text blocks are false if one of the transmitted blocks is corrupted?

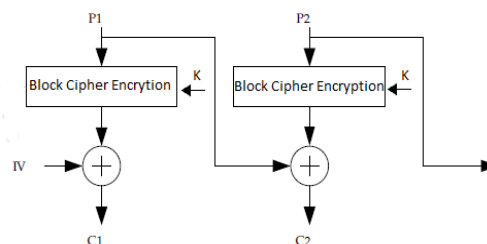


Figure 1. Plain Block Chaining

Encryption: $C_i = E_k(P_i) \oplus P_{i-1}$, $P_0 = IV$

Decryption: $P_i = D_k(C_i \oplus P_{i-1})$, $P_0 = IV$

All the subsequent blocks will decrypt incorrectly if there is a corrupt block or one block is lost.

CLO # 1: Explain key concepts of information security such as design principles.

Q3a: Diffie-Hellman is a classic protocol that provides mutual key exchange between different entities. One of the inherent weaknesses of Diffie-Hellman key exchange is that it does not provide entity authentication. Modify the Diffie-Hellman protocol such that it provides mutual Authentication between the entities (two in this case).

[05 marks]

- (1) Alice $\rightarrow$ Bob : g^x
(2) Alice $\leftarrow$ Bob : $g^y, E_K(S_B(g^y, g^x))$
(3) Alice $\rightarrow$ Bob : $E_K(S_A(g^x, g^y))$

Q3b: Text book RSA is considered to be insecure i.e. one should never encrypt by directly applying the RSA (pk, m) to plaintext. Propose a semantically secure Public-key crypto scheme using the RSA trap door permutation functions (TDFs).

[05

marks]

Review: RSA pub-key encryption (ISO std)

(E_s, D_s) : symmetric enc. scheme providing auth. encryption.

$H: X \rightarrow K$ where K is key space of (E_s, D_s)

- $G()$: generate RSA params: $pk = (N, e)$, $sk = (N, d)$
- $E(pk, m)$:
 - (1) choose random x in Z_N
 - (2) $y \leftarrow \text{RSA}(x) = x^e$, $k \leftarrow H(x)$
 - (3) output $(y, E_s(k, m))$
- $D(sk, (y, c))$: output $D_s(H(\text{RSA}^{-1}(y)), c)$

Q3c: Alice wants to send a secure message to Bob using the RSA encryption algorithm. To set up their communication, they agree on the following values: Prime numbers: $p = 7$ and $q = 17$, Encryption exponent: $e = 5$, Message to encrypt: $m = 9$

[05 marks]

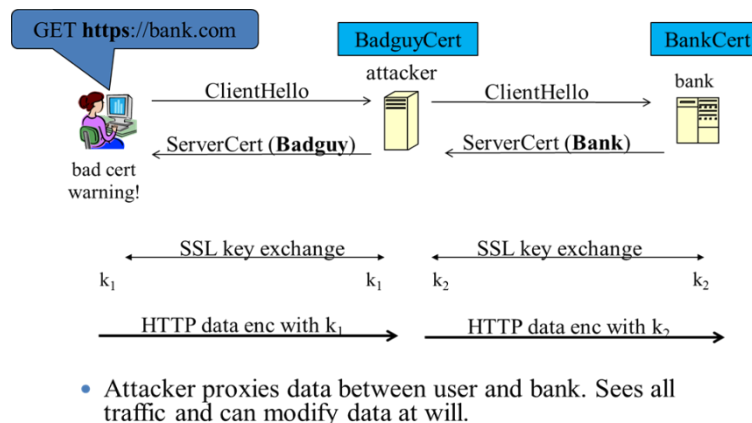
- i. Calculate the public key (e, n) for Alice and Bob's communication.

National University of Computer and Emerging Sciences

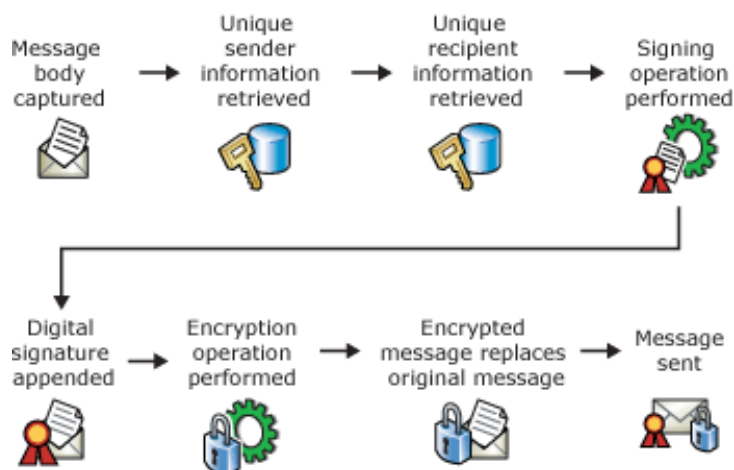
- ii. Determine the private key (d,n) using the provided values.
- iii. Encrypt the message m to find the ciphertext C .
- iv. Decrypt the ciphertext C to retrieve the original message m .

CLO # 3: Analyze and apply various security and risk management tools for achieving information security and privacy.

Q4a: The website of <https://bank.com/> loads with an invalid certificate. It is possible to exploit this vulnerability? If yes, Illustrate. **[05 marks]**



Q4b: Design a secure email architecture to provide end-to-end Confidentiality and Integrity? **[10 marks]**



CLO # 3: Analyze and apply various security and risk management tools for achieving information security and privacy.

Q5a: A web application allows users to view order details by specifying an order ID in the URL like this: <https://example.com/order?id=456> **[05 marks]**

The query is:

```
SELECT * FROM orders WHERE id = '$order_id';
```

National University of Computer and Emerging Sciences

- i. Craft and explain an SQL Injection payload to bypass the query and view all orders in the database.
- ii. Propose secure solutions to prevent SQL Injection.

Solution:

a. SQL Injection Payload:

Input for order_id: 456 OR 1=1

This transforms the query into:

```
SELECT * FROM orders WHERE id = 456 OR 1=1;
```

The condition 1=1 is always true, so all orders are returned.

b. Use parameterized queries to prevent SQL Injection:

- o Use Least Privilege Principle
- o Escape User Input
- o Validate and Sanitize User Input
- o Use Parameterized Queries

Q5b: A forum allows users to upload profiles with the following input:

[05 marks]

```
<input type="text" name="username">
```

- i. Create an XSS payload that executes JavaScript when another user views the profile.
- ii. Explain the difference between reflected XSS and stored XSS in this context.

Solution:

a. Payload for Profile Input:

Input: `<script>alert('Profile XSS');</script>`

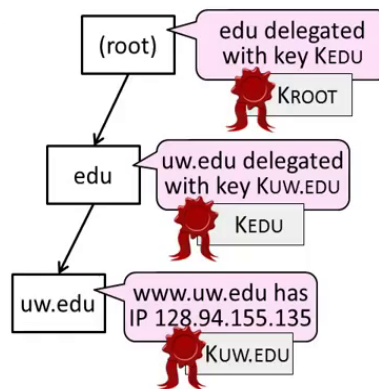
Executes whenever someone views the attacker's profile.

b. Difference Between Reflected and Stored XSS:

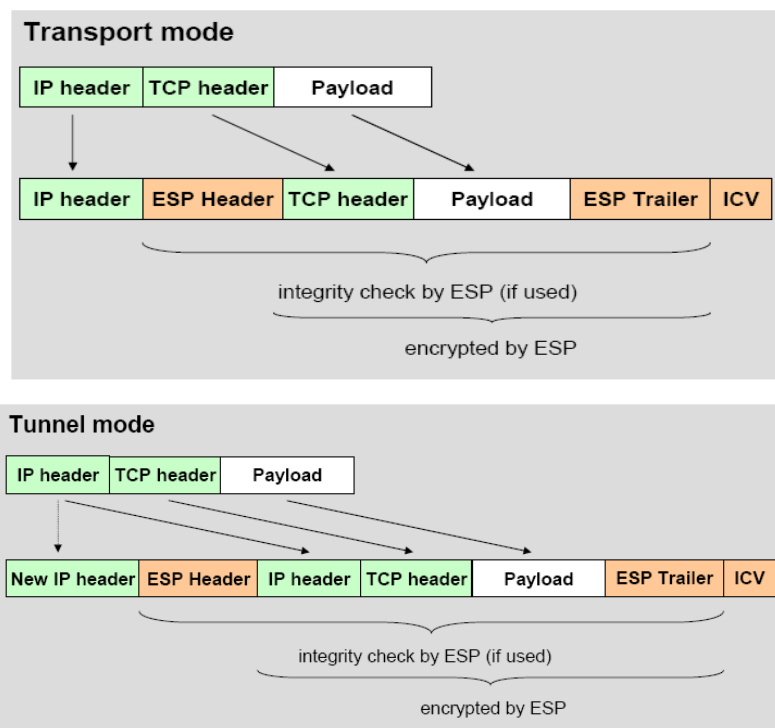
- **Reflected XSS:** Malicious script executes immediately in response to user input, often via URL parameters.
- **Stored XSS:** Malicious script is saved on the server (e.g., in a database) and executes when the data is displayed to other users.

CLO # 4: Identify appropriate techniques to tackle and solve problems of real life in the discipline of information security.

Q6a: Suppose a Client issues a DNS query for www.khi.nu.edu.pk. Illustrate how the replies to this query will be validated in DNSSEC. [05 marks]



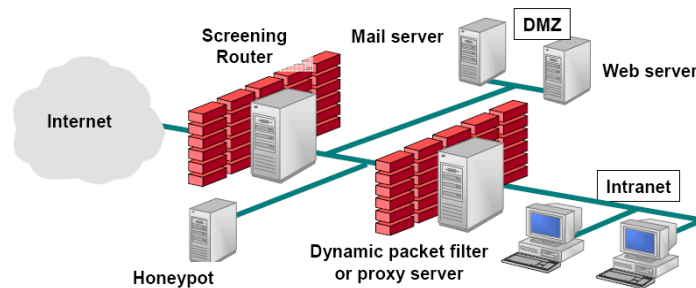
Q6b: Illustrate via figure how Encapsulating Security Payload Header can be used in Transport Mode and Tunnel Mode (clearly indicate the parts of IP packets that are encrypted or/and provided integrity check)? [05 marks]



Q6c: Suppose you are working as a network administrator in a major corporation. You have to propose a secure architecture for the network in such a way that your company's Webserver and

National University of Computer and Emerging Sciences

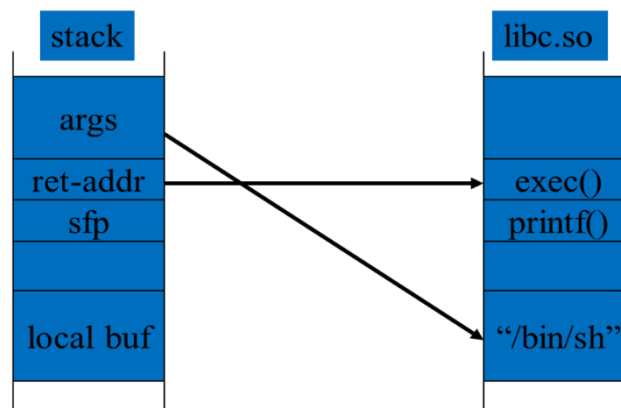
Mail server can be contacted from outside without any restriction and the intranet is kept hidden from outside. [05 marks]



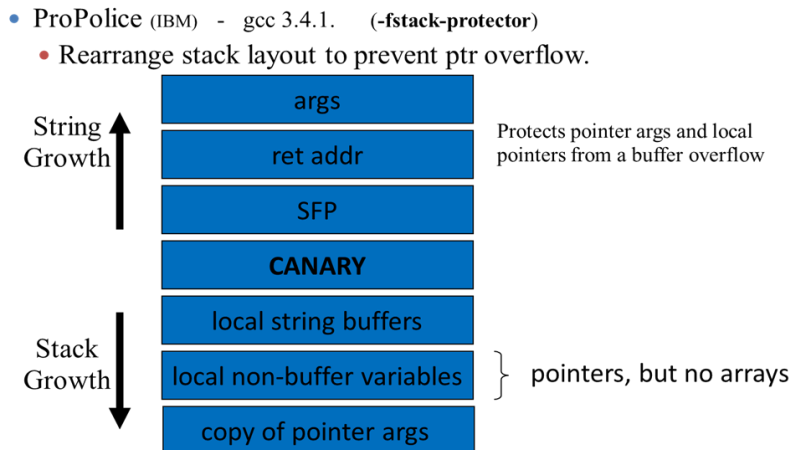
- Although possible: provide a weak faked server in your DMZ to attract attackers
- The honeypot does heavy logging and provides alarm systems instead of the real application services
- Goal: get knowledge about the attackers

CLO # 4: Identify appropriate techniques to tackle and solve problems of real life in the discipline of information security.

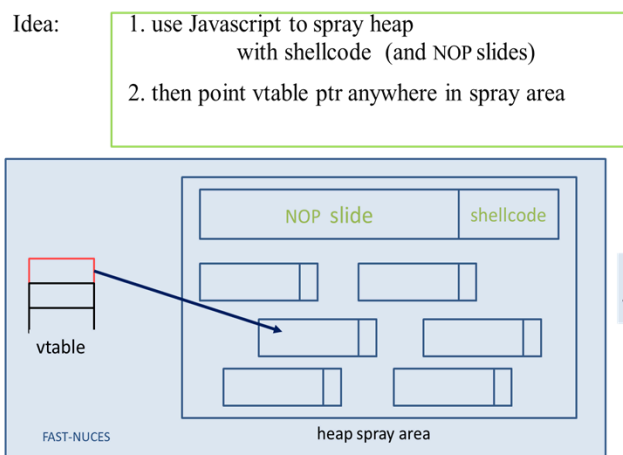
Q7a: Explain how is it possible to perform control hijacking where an attacker doesn't need to execute his own code? What would be the defense mechanism against such attacks? [05 marks]



Q7b: Propose a runtime scheme for Overflow prevention. Make sure that your scheme is also capable of preventing Pointer overflows. [05 marks]



Q7c: Explain the concept behind Heap Spraying. Are there any solutions to mitigate such attacks, explain? **[05 marks]**



CLO # 2: Discuss legal, ethical, and professional issues in information security.

Q8a: A hacker accesses and manipulates campaign documents of a political party to spread false narratives before an election. **[05 marks]**

- Identify two PECA 2016 clauses applicable to this situation
- What legal actions can be taken against the hacker?

Solution:

- Section 18 ("Unauthorized access") and Section 20 ("Malicious code").
- Prosecute under PECA for unauthorized manipulation and false information dissemination.

National University of Computer and Emerging Sciences

Q8b: A graduate researcher discovers that a senior academic in their department has published a paper that plagiarizes their unpublished thesis. **[05 marks]**

- i. How should the researcher address the situation while protecting their academic integrity?
- ii. Which professional ethics principles apply here?

Solution:-

- a) The researcher should gather evidence and report the incident to the academic ethics committee. Protecting intellectual property is paramount.
- b) Principle 1.3 (“Be honest and trustworthy”) and Principle 1.6 (“Give proper credit for intellectual property”) apply.